

LESSON GUIDE

Technology Plus

Unit 7: Security

6.1.1 – Confidentiality Concerns

Lesson Overview:

In this lesson, students will explore the CIA Triad with a focus on confidentiality. They will assess common confidentiality risks and learn to recognize attempts to compromise sensitive information.

Students will:

- Explain what the CIA triad is and how it is used as a model for securing data.
- Define confidentiality in relation to cybersecurity.
- Identify common threats and attacks that can compromise confidentiality.

Guiding Question: Why is data and information an asset, and what is the difference between critical data and non-critical data?

Suggested Grade Levels: 8-12

Technology Needed: Yes

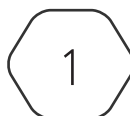
Approximate Time Required: 55-65 minutes

Standards:

CompTIA Tech+ FC0-U71 Objective

- 6.1 Explain fundamental security concepts and frameworks.
 - **Confidentiality**, integrity, and availability

This content is based upon work supported by the US Department of Homeland Security's Cybersecurity & Infrastructure Security Agency under the Cybersecurity Education Training and Assistance Program (CETAP).



CYBER.ORG
THE ACADEMIC INITIATIVE OF THE CYBER INNOVATION CENTER

Copyright © 2025 Cyber Innovation Center
All Rights Reserved. Not for Distribution.

Lesson Background

Background Information:

The CIA Triad is a foundational model in cybersecurity that highlights the three principles used to protect data: Confidentiality, Integrity, and Availability. Confidentiality ensures sensitive data is only accessible by authorized users and aims to prevent unauthorized access such as an accidental leak or intentional breach. Results of such a failure in confidentiality could lead to identity theft, privacy violations, reputational damage to an organization, or more. Integrity focuses on maintaining the accuracy of information and preventing unauthorized alteration of data. Availability of data emphasizes the importance of data being accessible for authorized users.

Materials Needed:

Materials per Class	• Lesson Guide • Lesson Slides 6.1.1 – Confidentiality Concerns • Lab 6.1.1 – Phishing Tips
Materials per Student	• Student Handout 6.1.2 – Confidentiality Concerns • Assessment 6.1.1 – Confidentiality Concerns

Cyber Terms:

Term	Definition
CIA Triad	a foundational model in information security comprising three core principles: • Confidentiality – restricting access to information to authorized individuals. • Integrity – ensuring information is accurate, consistent, and protected from unauthorized modification. • Availability – maintaining reliable and timely access to information for authorized users.
sniffing	monitoring and capturing network packets as they move through a network
social engineering	the manipulation of people through psychological or social tactics to gain unauthorized access to systems, data, or confidential information
phishing	type of online scam where criminals impersonate legitimate organizations to steal sensitive information

shoulder surfing	observing someone entering sensitive information, such as a password or pin
tailgating	gaining access to a secure area by following an authorized user through a secure entryway or security vestibule
eavesdropping	listening in on conversations to gain information which might occur in person or through electronic equipment
wiretapping	intercepting and monitoring phone or voice communications, including landlines, wireless networks, Wi-Fi, and Voice over IP (VoIP)
dumpster diving	retrieving discarded materials from dumpsters, trash cans, or recycling to steal sensitive information, often used for identity theft or unauthorized access

6.1.1 – Confidentiality Concerns

Guiding Question: What is the CIA triad and how can we ensure that confidential information remains confidential?

Lesson Launch: (3-5 minutes)

Where is My Data Stored?

- Engage students by having them think about an online account they use consistently.
- **Ask** how do they access that account and how does the website or platform know what they entered is correct?

Answers will vary.

- **Follow-up:** Ask students about the storage of their data related to gaining access to that account and/or the account data itself. What are some characteristics about the location, personnel, design, and other characteristics that students would want to see in a location that stores their personal data?

The CIA Triad and Threats to Confidentiality (30-40 minutes)

- Distribute Student Handout 6.1.1 – Confidentiality Concerns and encourage them to fill in answers as you go through today's lesson.

The CIA Triad

- The CIA Triad is a model used in cybersecurity to highlight the principles of confidentiality, integrity, and availability.
 - Confidentiality is securing the data from being viewed or accessed by any unauthorized individual.
 - Integrity means the data is trustworthy and free from unauthorized alteration.
 - Availability involves ensuring the data is available for authorized users when it is needed.

Confidentiality of Data

- Confidentiality means that the data is only viewable to the users who are authorized to view it.
- Examples include:
 - Credentials and other login details.
 - Personally Identifiable Information such as names, addresses, social security numbers.
 - Sensitive data such as health or finance records.

Threats to Confidentiality – Sniffing

- **Sniffing**, also called snooping, is the process of monitoring and capturing network traffic packets as they move through a network. Although most traffic nowadays is encrypted and packet sniffing isn't inherently malicious, it can still capture pieces of information that may lead to a breach in confidentiality.

- Using secure protocols, such as HTTPS, and modern wireless security with WPA2 and WPA3 keeps information encrypted and more secure.

Social Engineering Threats to Confidentiality

- Often users are the weakest link in cybersecurity.
- **Social engineering** is when someone uses common social interactions to gain access or confidential information from an authorized user through in-person or electronic means.
- **Phishing** uses electronic messaging, such as email, to gain information from an authorized user.
 - Smishing is phishing using text messages as the vector for phishing.
 - Vishing is using voice calls in phishing attempts.
- Phishing attempts should be ignored or reported through official channels. If the attempt involves an organization or person who is known, then contacting them directly to verify the authenticity of the message is recommended.
- **Shoulder surfing** occurs when a person watches a user enter sensitive information such as a pin or password.
- **Tailgating** involves entering a secure location by following a person through secured entryways or security vestibules.
- Social engineering effects can be mitigated through user awareness training and practice in recognizing its warning signs.

Additional Threats to Confidentiality

- **Eavesdropping** is the basic act of listening in on conversations to gain confidential information either in-person or with equipment.
- **Wiretapping** involves monitoring calls or communications over land lines or wireless methods.
- Being mindful of conversations and information shared over calls can assist in mitigating these methods.
- **Dumpster diving** involves going through discarded items in search of information or data. Physical destruction of data or the devices storing data prior to discarding them can alleviate this.

Lab: 6.1.1 – Phishing Tips (30-35 minutes)

- This activity requires access to the CYBER.ORG Range and the Kali Linux VM.
- It can be performed as a whole class activity or an independent student assignment.
- In the Kali VM, start by opening Firefox by clicking on its icon in the top left corner. Once Firefox has launched, open a terminal and use the command PhishingTips and hit [Enter]. This will open four pages in the browser, each showing a phishing attempt.
- Three of the pages are interactive, allowing additional information by hovering over links or other details. The goal for students is to analyze each and find the signs that phishing is occurring. Clicking on the links will trigger a pop-up alert saying that this is a cybersecurity test. Actual links are not real websites and will fail to load if further access is attempted.

- Once students identify the signs of phishing, they can add an explanation as to why they listed that sign. They also need to identify what information the attempt is trying to gain or what associated information a malicious actor could gain. Lastly, they will provide a proper way to respond.

Phishing Examples:

- Example 1: A call between someone claiming to work at City Utilities requesting account information for payment.
 - Signs of phishing include the tone of the person claiming to be from the utility company. Also, issues such as this would most likely occur through other means of communication such as letters or communication from official accounts that would note the account number instead of asking for it. Companies should not need to know a password associated with the account apart from rare cases such as home security companies that use code words for verifying who they are talking to.
- Example 2: An email about suspicious activity in a user's account.
 - The email lacks some details often seen in official correspondence. Use of general terms like "user" are often signs of a message sent in mass to hit several potential victims. The email does not mention which account. The key sign of phishing is hovering above the link to verify the account shows that it is a link to a potentially malicious site.
- Example 3: A second email about unusual login attempts.
 - This email is more detailed and specific to the user. The email is sent to a Gmail address so it should have an official email for the sender. Hovering on Support Team shows the email was sent from an unusual email address. Most Google emails are sent from a no-reply@"service".google.com i.e. no-reply@support.google.com or no-reply@accounts.google.com. Lastly, the link in the email does not go to Google or an account page and instead goes to a potentially malicious site.
- Example 4: A text message conversation about tracking a package.
 - The first thing to note is whether you are expecting a package or not. Most orders would be known, and the status of the shipment can be checked and verified through the respective service. Legitimate messages such as this are usually automated and do not allow responses or if they do, would not have a response such as seen here. Links in text messages require additional steps such as "long pressing" or holding down on it to view the details. The link included does have a more realistic link but does have a typo which is common in phishing attempts as a way to mimic legitimate sites.

Combining a Phishing Email with the Social Engineering Toolkit:

- After reviewing the examples, students will use the Social Engineering Toolkit to link a cloned Google sign-in page to create a more realistic example of phishing.
- It is important to note that even though this is an example and the information is not saved, students should not enter real credentials into the Google sign-in page they clone.

Putting It All Together (5-10 minutes)

Discussion Questions

- If you get an email from an unknown sender asking for your personal information, what should you do?

Students may respond with “You should not respond or give out any personal information or you can report the email as phishing.”

- What does the word “confidential” mean? Can you think of an example of something that should be kept confidential?

Students may respond with “Confidential means keeping something secret so that it is only accessible by those who are allowed to access it. Examples could be login credentials, personally identifiable information, financial data, student information, etc.”

- If someone gained access to your personal information, what could they potentially do with it?

Students may respond with “Use it to gain access to various accounts or steal your identity.”